Republic of the Philippines
POLYTECHNIC UNIVERSITY OF THE PHILIPPINES
SAN PEDRO CAMPUS
PUP, Main Road, Barangay United Bayanihan, City of San Pedro, Laguna

Batumbakal-Gym Database Roles and Privileges

Activity 4 Progress Documentation

1. Introduction

This document presents the progress of Activity 4: Database Users, Roles, Privileges, and Access Control for Group 09 – Batumbakal Gym.

The activity focuses on inspecting the PostgreSQL database, identifying existing user roles, checking assigned privileges, and testing access restrictions. It also evaluates the current database configuration based on the principle of least privilege.

2. Project Overview

Batumbakal Gym is a gym management system that uses PostgreSQL 18 as its database management system.

Project Name	Batumbakal Gym
Database	grp99_gymdb
Schema	public
DBMS	PostgreSQL 18
Backend	Java 25 – Spring Boot 4.1.2
Database Owner	postgres
Application Database Account	postgres

The database stores information related to gym members, trainers, classes, memberships, payments, and attendance. The application currently connects to the database using the postgres account.

3. Database Inspection

The database structure was inspected before checking its access-control configuration.

The inspection confirmed the following:

Database Component	Number
Application Schema	1
Tables	8
Sequences	7

The application schema contains the following tables:

Table Name	Description
attendance	Stores gym attendance records.
class_enrollments	Stores member class enrollment records.
classes	Stores gym class information.
members	Stores gym member information.
membership_plans	Stores available membership plans.
memberships	Stores member membership records.
payments	Stores payment records.
trainers	Stores trainer information.

The database itself is owned by postgres. The inspected application tables and sequences are located in the public schema.

4. Role Creation and Configuration

The existing PostgreSQL roles were inspected to identify their login capabilities and responsibilities.

The inspection identified the following relevant accounts and roles:

Role Name	Login Capability	Description
postgres	LOGIN	PostgreSQL superuser used by the application to connect to the database.
activity4_test_role	NOLOGIN	Existing test role used to check restricted database access.
gym_app	Not Found	Application role mentioned in the project's role documentation but not found during inspection.
gym_readonly	Not Found	Read-only role mentioned in the project's role documentation but not found during inspection.

The postgres account has superuser privileges, including the ability to create databases and roles. The application currently uses this account instead of a dedicated application account.

The inspection also confirmed that gym_app and gym_readonly were not present in the PostgreSQL roles checked. No membership records involving these two roles were found.

The activity4_test_role account was configured as a NOLOGIN role with restricted privileges. It was used for access-control testing to verify whether database operations would be denied when the required permissions were not assigned.

5. Privilege Assignment

The existing PostgreSQL privileges were inspected to determine the permissions assigned to the application account and the test role.

5.1 Database and Schema Privileges

The postgres account has the following database privileges on grp99_gymdb:

- CONNECT
- CREATE
- TEMPORARY

The activity4_test_role account has CONNECT permission but does not have CREATE or TEMPORARY privileges.

For the public schema, the test role has USAGE permission but does not have CREATE permission.

5.2 Table Privileges

The postgres account has SELECT, INSERT, UPDATE, and DELETE privileges on all eight application tables.

Meanwhile, the activity4_test_role account does not have any of these privileges on the eight tables.

5.3 Sequence Privileges

The activity4_test_role account does not have USAGE or SELECT privileges on the seven sequences inspected in the public schema.

No additional sequence privileges were granted to this test role during the inspection.

5.4 Group Roles

The inspection did not identify the gym_app and gym_readonly roles in the PostgreSQL role list.

The existing activity4_test_role was used to test restricted access. No new group roles were created during the inspection.

5.5 Default Privileges

No default-privilege inspection result was recorded in the tests completed so far. Therefore, the default privileges for future tables and sequences are not yet confirmed.

6. Access Control Testing

The existing database accounts were tested to verify whether their assigned privileges allowed or restricted specific database operations.

6.1 Application Database Account

The postgres account was identified as the database account used by the Batumbakal Gym application.

Operation	Expected Result	Actual Result
SELECT from application tables	Allowed	Allowed
INSERT into application tables	Allowed	Allowed
UPDATE application tables	Allowed	Allowed
DELETE from the application tables	Allowed	Allowed

The privilege inspection confirmed that postgres has all four tested table privileges on the eight application tables.

6.2 Test Role Accout

The existing activity4_test_role was used to verify restricted database access.

The following operations were attempted:

Operation	Expected Result	Actual Result
CONNECT to database	Allowed	Successful
SELECT from members	Denied	Permission denied
INSERT into members	Denied	Permission denied
UPDATE members	Denied	Permission denied

DELETE from members	Denied	Permission denied

The UPDATE and DELETE statements used WHERE 1=0 to avoid modifying existing records. The operations were denied because the test role did not have the required table privileges.

6.3 Schema Owner Account

The sequence privileges of activity4_test_role were also inspected.

The results confirmed that the role does not have USAGE or SELECT privileges on the seven sequences in the public schema.

6.4 Testing Summary

The access-control inspection and tests confirmed the following:

- The application connects to PostgreSQL using the postgres superuser account.
- The postgres account has SELECT, INSERT, UPDATE, and DELETE privileges on all eight application tables.
- The activity4_test_role can connect to the database.
- The test role cannot read or modify the members table.
- The test role does not have the inspected sequence privileges.
- The denied operations did not modify existing records.

6.5 Application Integration Testing

The Batumbakal Gym website was opened and inspected through the running application.

The website provides direct access to the dashboard without requiring a login. No application-level authentication or role-based access control was identified during the inspection.

The database connection was also observed through PostgreSQL activity inspection, which showed connections from the PostgreSQL JDBC Driver using the postgres account.